

[TEN TRUONG DAI HOC]

[KHOA / VIEN]

**BAN THUYET MINH THIET KE
SU DUNG AI LAP KE HOACH VA TAN CONG
TRONG ISOLATED WEB CYBER RANGE**

(Pham vi SQL Injection, Cross-Site Scripting va Path Traversal)

Sinh vien thuc hien: [HO VA TEN]

Ma so sinh vien: [MSSV]

Lop: [LOP]

Giang vien huong dan: [HO VA TEN GVHD]

[Noi -- Nam]

LỜI LƯU Ý VỀ TRẠNG THÁI BẰNG CHỨNG

Tài liệu này là bản thuyết minh thiết kế. Hệ thống đang được xây dựng, chưa có kết quả thực nghiệm. Các nội dung về so sánh hiệu năng, số liệu và xếp hạng planner là DỰ KIẾN dựa trên thiết kế — không phải kết quả đo được.

MỤC LỤC

1. TÍNH CẤP THIẾT CỦA ĐỀ TÀI.....	3
1.1. Kiểm thử bảo mật web là công việc tốn kém và phụ thuộc chuyên gia..	3
1.2. AI có thể tự động hóa quy trình lập kế hoạch tấn công	3
1.3. Khoảng trống: chưa có khung so sánh các chiến lược AI tấn công	3
1.4. Tại sao phải dùng Isolated Web Cyber Range?	3
2. MỤC TIÊU ĐỀ TÀI.....	5
2.1. Mục tiêu tổng quát.....	5
2.2. Mục tiêu cụ thể	5
3. PHẠM VI VÀ ĐỐI TƯỢNG NGHIÊN CỨU	6
3.1. Đối tượng nghiên cứu.....	6
3.2. Trong phạm vi nghiên cứu	6
3.3. Ngoài phạm vi	6
4. PHƯƠNG PHÁP NGHIÊN CỨU	7
4.1. Mô hình hóa bài toán tấn công thành MDP	7
4.2. Bốn chiến lược AI và sự khác biệt cơ bản	7
4.3. Thiết kế thí nghiệm so sánh công bằng	8
4.4. Đo lường hiệu quả tấn công	8
5. KẾT QUẢ DỰ KIẾN	9
5.1. Hệ thống AI tấn công web tự động có thể vận hành	9
5.2. Dữ liệu so sánh bốn chiến lược planner trên từng lớp lỗ hổng	9
5.3. Phân tích sự khác biệt giữa ba lớp lỗ hổng	9
5.4. Protocol so sánh có thể tái sử dụng	9
6. CẤU TRÚC BÁO CÁO DỰ KIẾN	11
7. SƠ ĐỒ THIẾT KẾ	12
TÀI LIỆU THAM KHẢO VÀ NGUỒN NỘI BỘ	13

1. TÍNH CẤP THIẾT CỦA ĐỀ TÀI

1.1. Kiểm thử bảo mật web là công việc tốn kém và phụ thuộc chuyên gia

Kiểm thử bảo mật ứng dụng web — đặc biệt với ba lớp lỗ hổng SQL Injection, Cross-Site Scripting và Path Traversal — đòi hỏi người kiểm thử phải thủ công lập kế hoạch tấn công từng bước: chọn vector, chọn payload, gửi request, đọc phản hồi, điều chỉnh và thử lại. Một pentester có kinh nghiệm có thể mất từ vài giờ đến vài ngày để kiểm thử một endpoint, và khả năng phát hiện lỗ hổng phụ thuộc lớn vào trực giác và kinh nghiệm cá nhân. Khi số lượng ứng dụng cần kiểm thử tăng, cách tiếp cận thủ công này không thể mở rộng được.

1.2. AI có thể tự động hóa quy trình lập kế hoạch tấn công

Kiểm thử bảo mật có cấu trúc rõ ràng phù hợp để AI học và tự động hóa: mỗi bước tấn công có thể được mô tả thành trạng thái hiện tại (ứng dụng phản hồi gì, lỗ hổng đã xác nhận chưa), hành động tiếp theo (gửi payload nào, vector nào) và kết quả quan sát. Đây chính xác là cấu trúc mà AI planning — đặc biệt là Reinforcement Learning — được thiết kế để giải quyết. Thay vì người kiểm thử phải nhớ từng payload và logic thử, AI có thể tự động học các pattern khai thác và đưa ra kế hoạch tấn công có thứ tự, có logic dựa trên trạng thái thực tế của mục tiêu.

1.3. Khoảng trống: chưa có khung so sánh các chiến lược AI tấn công

Có nhiều cách để AI lập kế hoạch tấn công: viết quy tắc cứng tắt định (RULE), dùng mô hình ngôn ngữ lớn sinh kế hoạch theo prompt (LLM), huấn luyện agent học tăng cường trong môi trường lab (RL), hoặc kết hợp nhiều nguồn đề xuất (HYBRID). Mỗi chiến lược có điểm mạnh khác nhau — RULE ổn định và có thể audit được; LLM linh hoạt nhưng khó kiểm soát; RL có thể tìm ra chuỗi tấn công mà người chưa nghĩ đến; HYBRID là kết hợp lý thuyết — nhưng chưa có khung nào cho phép so sánh công bằng bốn chiến lược này trên cùng môi trường, cùng kịch bản, cùng ngân sách hành động. Điều này khiến các kết luận "AI chiến lược X tốt hơn Y" thiếu cơ sở hợp lệ. Đề tài xây dựng chính xác khung đó.

1.4. Tại sao phải dùng Isolated Web Cyber Range?

Nghiên cứu về AI tấn công không thể thực hiện trên hệ thống thật vì lý do an toàn và pháp lý. Isolated Web Cyber Range giải quyết vấn đề này: đây là môi trường lab cô lập, mục tiêu được kiểm soát, hành động của AI chỉ ảnh hưởng đến hệ thống nội bộ. Điều này cho phép AI được phép thử nghiệm đầy đủ các chiến lược tấn công — kể cả những hành động thất bại — mà không gây hại ngoài thế giới. Ngoài ra, môi trường

cô lập đảm bảo tính tái lập: cùng kịch bản, cùng mục tiêu, cùng điều kiện ban đầu cho mỗi lần chạy, giúp so sánh giữa các chiến lược AI là có ý nghĩa.

2. MỤC TIÊU ĐỀ TÀI

2.1. Mục tiêu tổng quát

Xây dựng hệ thống AI có khả năng tự động lập kế hoạch và thực thi tấn công web trong môi trường Isolated Web Cyber Range, so sánh hiệu quả của bốn chiến lược planning — RULE, LLM, RL và HYBRID — trên ba lớp lỗ hổng SQL Injection, XSS và Path Traversal, và phân tích điểm mạnh-yếu của từng chiến lược trong việc tìm ra chuỗi hành động tấn công thành công.

2.2. Mục tiêu cụ thể

- Xây dựng pipeline tự động: từ mô tả kịch bản tấn công, AI tự lập kế hoạch (chọn hành động theo thứ tự), thực thi và ghi nhận kết quả quan sát để quyết định bước tiếp theo.
- Triển khai bốn chiến lược planner trên cùng nền tảng: RULE là baseline tất định; LLM sinh kế hoạch từ prompt; RL huấn luyện agent học chuỗi hành động tối ưu; HYBRID kết hợp candidate từ nhiều nguồn.
- Đảm bảo mỗi planner chạy trong cùng không gian hành động, cùng ngân sách và cùng kịch bản — để so sánh là hợp lệ và có ý nghĩa.
- Đo lường hiệu quả tấn công: tỷ lệ kịch bản thành công, số bước để đạt mục tiêu, tỷ lệ hành động hợp lệ và khả năng phát hiện lỗ hổng đúng.
- Phân tích điểm mạnh-yếu của từng chiến lược trên từng lớp lỗ hổng: SQL Injection, XSS, Path Traversal có đặc điểm cấu trúc khác nhau, tìm hiểu xem AI nào hiệu quả hơn với loại nào và lý do.

3. PHẠM VI VÀ ĐỐI TƯỢNG NGHIÊN CỨU

3.1. Đối tượng nghiên cứu

Đối tượng chính là bốn chiến lược AI planning cho tấn công web tự động: RULE, LLM, RL và HYBRID. Môi trường nghiên cứu là Isolated Web Cyber Range với ba lớp lỗ hổng — SQL Injection, XSS và Path Traversal — trên các mục tiêu lab được định nghĩa trước. Quá trình nghiên cứu tập trung vào khả năng lập kế hoạch và thực thi tấn công của AI, không phải phát triển công cụ quét lỗ hổng mới hay nghiên cứu lỗ hổng zero-day.

3.2. Trong phạm vi nghiên cứu

- Ba lớp lỗ hổng: SQL Injection (error-based, union-based), XSS (reflected, stored), Path Traversal — đủ để thể hiện cấu trúc tấn công khác nhau mà vẫn kiểm soát được trong lab.
- Bốn chiến lược planner với cùng catalog hành động, cùng điều kiện và cùng cách đo hiệu quả — so sánh công bằng.
- Môi trường hoàn toàn cô lập: mục tiêu là hệ thống lab cố định, không kết nối Internet, không ảnh hưởng hệ thống bên ngoài.
- Chuỗi hành động tấn công có cấu trúc: mỗi bước là một hành động có type, có trạng thái đầu vào và quan sát đầu ra; AI phải đưa ra quyết định bước tiếp theo dựa trên kết quả thực tế.

3.3. Ngoài phạm vi

- Hệ thống production, mục tiêu công khai trên Internet, bất kỳ môi trường ngoài lab.
- Các lớp lỗ hổng ngoài SQL Injection, XSS, Path Traversal.
- Phát triển payload mới hay khai thác zero-day — AI chỉ chọn từ catalog hành động đã định nghĩa.
- Kết quả so sánh định lượng: chưa có vì thực nghiệm chưa chạy; các con số cụ thể chỉ được đưa vào sau khi có evidence.

4. PHƯƠNG PHÁP NGHIÊN CỨU

4.1. Mô hình hóa bài toán tấn công thành MDP

Quá trình tấn công web có cấu trúc phù hợp với MDP — Markov Decision Process — là mô hình toán học cho bài toán quyết định tuần tự. Trong đó: trạng thái S mô tả toàn bộ thông tin AI đang biết về mục tiêu (đã gửi payload nào, phản hồi là gì, có xác nhận lỗ hổng chưa); hành động A là tập các bước tấn công có thể thực hiện tiếp theo lấy từ catalog đã định nghĩa; chuyển trạng thái T mô tả mục tiêu sẽ ở trạng thái nào sau khi AI thực hiện hành động a từ trạng thái s ; phần thưởng R khuyến khích AI hướng đến mục tiêu (khai thác thành công lỗ hổng) và giảm trừ khi dùng hành động thừa hoặc hết ngân sách. Với POMDP, AI duy trì belief (phân phối xác suất trên các trạng thái có thể) và cập nhật belief sau mỗi quan sát — phù hợp với thực tế khi AI không biết chính xác trạng thái nội bộ của ứng dụng mục tiêu.

4.2. Bốn chiến lược AI và sự khác biệt cơ bản

RULE — baseline tất định: Planner tra bảng quy tắc cố định — nếu quan sát X thì thực hiện hành động Y . Hoàn toàn có thể audit, tạo ra kết quả giống hệt mỗi lần chạy, nhưng không thích nghi được với tình huống ngoài tập quy tắc đã viết. Nếu RULE đạt hiệu quả cao, chúng ta vấn đề đã được hiểu tốt; nếu thấp, chúng ta có sự phức tạp mà quy tắc cứng không đủ.

LLM — mô hình ngôn ngữ: Planner gửi trạng thái hiện tại vào mô hình ngôn ngữ lớn theo dạng prompt có cấu trúc và nhận lại kế hoạch hành động theo schema định trước. Ưu điểm là LLM có kiến thức rộng về các kỹ thuật tấn công và có thể xử lý tình huống phức tạp bằng ngôn ngữ tự nhiên; có thể đề xuất hành động hợp lý ngay cả khi gặp quan sát chưa từng thấy. Nhược điểm: LLM có thể "tự tin sai" — sinh hành động có vẻ logic nhưng không tồn tại trong catalog, hoặc đề xuất chuỗi bước thừa.

RL — reinforcement learning: Agent học chính sách tấn công bằng cách tương tác với môi trường lab — thử hành động, nhận phần thưởng, cập nhật chính sách qua hàng trăm đến hàng nghìn episode. Ưu điểm lớn là RL có thể khám phá chuỗi hành động mà cả chuyên gia chưa nghĩ đến, và tối ưu hóa theo tiêu chí cụ thể (tìm ra lỗ hổng nhanh nhất với ít bước nhất). Nhược điểm: cần nhiều episode để hội tụ, dễ học hành vi sai nếu reward function không chính xác, và chính sách học được khó giải thích.

HYBRID — kết hợp: Kết hợp đề xuất từ nhiều nguồn — ví dụ RULE tạo ra tập hành động ứng viên, LLM xếp hạng, RL tinh chỉnh theo kinh nghiệm. Lý thuyết là HYBRID bù đắp điểm yếu của từng chiến lược đơn lẻ; nhưng trong thực tế HYBRID

khó debug hơn và khó xác định nguyên nhân khi kế hoạch sai. HYBRID là hướng thử nghiệm đáng giá xem có gain thực sự so với đơn lẻ hay không.

4.3. Thiết kế thí nghiệm so sánh công bằng

Để so sánh bốn chiến lược là hợp lệ, mỗi thí nghiệm phải đảm bảo: cùng kịch bản và mục tiêu; cùng action budget (số hành động tối đa AI được phép thử); seed cố định khi RL có randomness; ground truth độc lập xác nhận kết quả; và version của tất cả thành phần được ghi lại để có thể chạy lại. Nếu bất kỳ điều kiện nào khác nhau giữa hai lần so sánh, kết luận rút ra sẽ không có giá trị. Đây là ý nghĩa của "so sánh công bằng" — không phải các chiến lược giống nhau, mà là điều kiện thí nghiệm là giống nhau.

4.4. Đo lường hiệu quả tấn công

Các metric dự kiến đo liên quan trực tiếp đến hiệu quả tấn công: (1) Task success rate — tỷ lệ kịch bản mà AI tìm ra chuỗi hành động dẫn đến khai thác lỗ hổng thành công; đây là chỉ số hiệu quả chính. (2) Số bước trung bình — số hành động AI thực hiện trước khi đạt mục tiêu hoặc hết ngân sách; planner hiệu quả hơn sẽ đạt mục tiêu trong ít bước hơn. (3) Valid-action rate — tỷ lệ hành động AI đề xuất tồn tại trong catalog và hợp lệ trong trạng thái hiện tại; tách biệt "AI hiểu không gian hành động" với "AI tìm ra kế hoạch tốt". (4) Exploration coverage — tỷ lệ không gian hành động mà AI đã thử ít nhất một lần trong tập kịch bản; cần biết để đánh giá có phải AI quá tập trung vào một số vector hay không. (5) Số episode cần hội tụ — chỉ với RL — biết RL cần bao nhiêu lần thử mới bắt đầu hoạt động hiệu quả, để đánh giá tính khả thi trong thực tế.

5. KẾT QUẢ DỰ KIẾN

Tất cả kết quả dưới đây là DỰ KIẾN dựa trên thiết kế — hệ thống chưa chạy, chưa có số liệu đo. Phần này mô tả những gì đề tài hướng đến và tại sao chúng có ý nghĩa.

5.1. Hệ thống AI tấn công web tự động có thể vận hành

Kết quả vật chất đầu tiên là hệ thống hoạt động được: AI nhận vào mô tả kịch bản, tự quan sát trạng thái mục tiêu, tự chọn hành động tiếp theo và thực hiện, ghi nhận kết quả và lặp lại cho đến khi đạt mục tiêu hoặc hết ngân sách. Nếu hệ thống này chạy được ổn định, nó chứng minh tính khả thi của việc dùng AI để tự động hóa một công việc trước đây hoàn toàn thủ công của pentester.

5.2. Dữ liệu so sánh bốn chiến lược planner trên từng lớp lỗ hổng

Kết quả có giá trị nhất không phải là "planner nào giỏi nhất" mà là hiểu được trong trường hợp nào thì chiến lược nào phù hợp. Giả thuyết thiết kế: RULE sẽ hoạt động ổn định nhưng bị giới hạn khi lỗ hổng có nhiều biến thể; LLM sẽ linh hoạt hơn nhưng có thể mất nhiều hành động không cần thiết; RL có thể tìm ra chuỗi tấn công ngắn và hiệu quả sau khi huấn luyện nhưng sẽ kém ở giai đoạn đầu; HYBRID chưa rõ — do thí nghiệm quyết định. Những giả thuyết này cần được xác nhận hoặc bác bỏ bằng số liệu thực.

5.3. Phân tích sự khác biệt giữa ba lớp lỗ hổng

SQL Injection có cấu trúc phản hồi rõ ràng (lỗi SQL hiện ra, hay dữ liệu trả về thay đổi) nên RULE và RL có thể học tốt. XSS có nhiều biến thể hơn (reflected, stored, DOM-based) và phụ thuộc vào ngữ cảnh nên LLM có thể có ưu thế. Path Traversal phụ thuộc vào cấu trúc hệ thống tệp — khó dự đoán — nên có thể là case thú vị nhất để xem chiến lược nào xử lý tốt bất định nhất. Những phân tích này là giả thuyết cần thí nghiệm kiểm chứng, không phải kết luận.

5.4. Protocol so sánh có thể tái sử dụng

Ngoài kết quả so sánh cụ thể, đề tài đóng góp một protocol: cách thiết kế môi trường lab, cách định nghĩa kịch bản, cách đo hiệu quả và cách ghi nhận kết quả để người khác có thể kiểm tra lại hoặc mở rộng sang lớp lỗ hổng mới. Đây là đóng góp phương pháp luận có thể tái sử dụng sau khi đề tài này kết thúc.

Kết quả dự kiến	Mô tả	Ý nghĩa
-----------------	-------	---------

Hệ thống AI tấn công chạy được	Pipeline tự động: quan sát -> kế hoạch -> thực thi -> lặp lại	Chứng minh tính khả thi tự động hóa kiểm thử web bằng AI
So sánh 4 chiến lược planner	Task success rate, số bước, valid-action rate trên SQL/XSS/Path Traversal	Biết chiến lược nào phù hợp loại lỗ hổng nào và tại sao
Phân tích điểm mạnh-yếu	RULE vs LLM vs RL vs HYBRID: khi nào tốt, khi nào kém	Hướng dẫn chọn chiến lược trong ứng dụng thực tế
Protocol so sánh tái lập	Kịch bản, metric, điều kiện thí nghiệm được tài liệu hóa	Người khác có thể mở rộng sang lỗ hổng khác hoặc môi trường khác
Insight về cấu trúc tấn công	AI hiểu cấu trúc tấn công thế nào, bước nào hay bị bỏ qua	Hiểu sâu hơn về đặc điểm từng lớp lỗ hổng qua lens của AI

6. CẤU TRÚC BÁO CÁO DỰ KIẾN

Báo cáo mở rộng dự kiến gồm 11 chương. Chương 9 sẽ được điền sau khi có kết quả thí nghiệm.

Chương	Tên chương	Nội dung chính
1	Giới thiệu	Bối cảnh, vấn đề, mục tiêu, phạm vi, đóng góp.
2	Cơ sở lý thuyết	AI planning, MDP/POMDP, RL, web vulnerabilities, automated pentesting.
3	Công trình liên quan	Các hệ thống AI-assisted pentesting hiện có; hạn chế; khoảng trống.
4	Phát biểu bài toán	Mô hình hóa tấn công web thành MDP; định nghĩa S, A, T, R.
5	Kiến trúc hệ thống	Pipeline tự động; các thành phần; giao tiếp giữa planner và môi trường.
6	Thiết kế bốn planner	RULE, LLM, RL, HYBRID: thiết kế chi tiết, điều kiện hoạt động, hạn chế.
7	Triển khai	Cài đặt cụ thể; catalog hành động; kịch bản; môi trường lab.
8	Phương pháp thí nghiệm	Kịch bản kiểm thử; metric; điều kiện so sánh; ghi nhận kết quả.
9	Kết quả và phân tích	[DỰ KIẾN -- điền sau khi có dữ liệu thí nghiệm]
10	Thảo luận	Giải thích kết quả; hạn chế; hướng mở rộng.
11	Kết luận	Tóm tắt đóng góp; bài học; hướng tương lai.

Phụ lục dự kiến: catalog hành động và payload mẫu; schema trạng thái và quan sát; kịch bản thí nghiệm chi tiết; định nghĩa metric đầy đủ; bảng kết quả thô; hướng dẫn chạy lại thí nghiệm.

7. SƠ ĐỒ THIẾT KẾ



Hình 1. Pipeline AI tự động lập kế hoạch và tấn công — sơ đồ thiết kế dự kiến.

Mọi trust crossing phải được xác thực và chuẩn hóa. Dữ liệu sai khuôn dạng hoặc thiếu trường bắt buộc bị từ chối, không được suy đoán.

Hình 2. Biên giới môi trường lab và kiểm soát hành động — chỉ chạy trong cyber range cô lập.



Hình 3. Vòng MDP/POMDP: AI quan sát, chọn hành động, nhận kết quả và quyết định bước tiếp theo.

TÀI LIỆU THAM KHẢO VÀ NGUỒN NỘI BỘ

Nguồn nội bộ: README.md; docs/architecture.md; docs/planning-model.md; docs/mdp-pomdp-model.md; docs/experiment-design.md; docs/metrics.md; report/chapters/01 đến 11; action/scenario/config schemas.

Tài liệu ngoài trong docs/references.md hiện chưa được xác minh phiên bản; danh sách sẽ được cập nhật khi có evidence truy xuất.